BA ZC581 :
Applied Data Science
Module: 14

J A Gokhale.

BITS Pilani
Pilani | Dubai | Goa | Hyderabad

Disclaimer

- The slides presented here are obtained / extracted from the authors of the prescribed books and from various other subject contributors.
- I hereby thank and acknowledge all the contributors for their material and inputs.
- I have added and modified a few slides to suit the requirements of the course.

innovate achieve lead

BITS Pilani

Pilani|Dubai|Goa|Hyderabad

Module 14:
Data Ethics and Governance

Module 14 Topics

Topic 1: Introduction To Data Ethics & Governance

Topic 2: GDPR, HIPPA etc

Topic 3: Anonymization

Topic 4: Responsible AI and Sustainability in AI

Ref: T1 , Ch 11.10, 13

innovate achieve lead

BITS Pilani

Pilani|Dubai|Goa|Hyderabad

Topic 1: Introduction to Data Ethics & Governance

Data Governance: Introduction

- Data ethics & governance refers to standards and principled approach to managing data during its life cycle, from responsible collection, use, sharing and management of data including its disposal.
- For an organization, it means setting internal standards and data policies
  - It governs who can access what kinds of data and what kinds of data are under governance.
  - Data governance also involves complying with external standards set by industry associations, government agencies, and other stakeholders.

Data Governance

- Data Governance is a subset of Data Management.
- It is about
  - Quality, Security and availability of Data in an organization
  - Data integrity, policy-based access and security
- The goal is to maintain safe, high-quality data that is easily accessible for data discovery and business intelligence initiatives.
- The data governance function helps ensure that verified data flows through secured pipelines to trusted endpoints and users.

Data Governance & Data Management

- Data Governance is a subset of Data Management.
- Data management includes data governance, it also includes other areas of the data lifecycle, such as data collection, processing, storage, access and data security.
- Example – data access:
  - A data governance team might set the policies concerning access to specific types of data, such as personally identifiable information (PII).
  - Then, a data management team will provide that access directly or create the mechanism to provide that access, often through role-based access control (RBAC).

Data Ethics & Governance

Why it Matters?

- Explosion of big data, AI, and automation
- Increased privacy concerns
- Regulatory pressures
- Reputational and trust risks

Core Ethical Principles

- Privacy & Confidentiality
- Transparency
- Fairness & Non-discrimination
- Accountability
- Consent & User Control

Facial recognition systems showing bias due to non-representative training datasets → Ethical failure in fairness.

Objectives

- Ensure data accuracy and integrity
- Define ownership and accountability
- Manage data lifecycle (creation → storage → archival → deletion)
- Ensure regulatory compliance

Key Components

- Data policies & standards
  - Depends on the domain of operations
- Data stewardship roles
- Data quality management
- Metadata management
- Access controls & security

Ethics vs. Governance

- Ethics = What should we do? (Values-based)
- Governance = How do we implement and control it? (Operational framework)

Governance & Data Domains

- Governance can be applied within meaningful business contexts, known as data domains.
- These domains define logical groupings of data based on how it is used within the organization.
- Specific domains will differ based on industry

Example Data Domains for Retail Industry

Customer — Information about individuals or organizations who buy or use your products or services.

Product — Details about the goods or services offered, including structure, pricing, and descriptions.

Supplier — Information about vendors, their contracts, and how they perform.

Financial — Records of income, expenses, budgets, and other financial transactions.

Employee — Information about staff, including roles, compensation, and HR history.

Sales — Data on purchases, transactions, and revenue-generating activities.

Inventory & supply chain — Tracks stock levels, product movement, and delivery processes.

Marketing & campaigns — Captures campaign activity, ad spend, and market targeting strategies.

Compliance & regulatory — Data used to meet legal, audit, and regulatory obligations.

Digital & web analytics — Measures how users interact with digital platforms and websites.

Ethics Privacy and Compliance monitoring

- Frameworks and Tools support the enforcement and monitoring of ethical data use, privacy regulations (e.g., GDPR, HIPAA), and internal policies.
- They provide capabilities for data subject rights management, consent tracking, audit trails, and usage monitoring, which are critical for building trust and meeting regulatory obligations.

Policy & Standard

- Policies and standards are the foundation of data governance. They define the rules, expectations, and responsibilities.
- Policies set the direction, and standards make it operational.
- A *policy* says what must be done. It's a clear rule, like "customer data must be protected."
- A *standard* says how to do it. It gives the details, like "encrypt customer data and keep it for 3 years."

Data Ownership and Roles

- Clear ownership roles are essential to making data governance work in practice.
- When business process, system, data product, and data owners each understand their responsibilities, organizations can manage data more effectively,
  - avoid gaps or overlaps
  - ensure that data is well-governed and delivering value.

4 Types of Data Owners & Roles in Data Management

	Business Process Owner	System Owner	Product Owner	Data Owner
Definition / Description	Accountable for a specific business process overall, including data-related aspects such as sourcing from the right systems, using data in line with policies and standards, and ensuring data is created and managed appropriately.	Accountable for a specific application or platform, responsible for its technical operation, security, and performance, and for ensuring it meets defined requirements while supporting the processes and data it enables.	Accountable for delivering and evolving a product (including a data product) to meet business and user needs, ensuring it delivers value, meets requirements, and remains relevant over its lifecycle.	Accountable for a data domain including setting and enforcing quality, compliance, and usage standards, and defining requirements for how this data should be captured, stored, and managed within relevant systems.
Level of Definition	**Business Process –** A sequence of activities delivering a business outcome, often spanning multiple teams and systems.	**System or Platform –** A software environment that stores, processes, or delivers data and functionality.	**Product or Data Product –** A packaged set of data, tools, and/or services delivered as a product with defined value and lifecycle.	**Data Domain –** A defined set of data with business meaning and governance requirements.
Common Responsibilities	▪ Define process requirements ▪ Ensure business process is compliant ▪ Source and use data in line with policies, standards, and approved usage scenarios ▪ Drive continuous improvement ▪ Approve process-related changes	▪ Operate the platform subject to defined requirements (e.g., uptime, security, user access) ▪ Coordinate upgrades ▪ Ensure integration with other systems ▪ Support audits and compliance ▪ Support data quality and governance ▪ Manage technical and operational metadata	▪ Define product vision and backlog ▪ Prioritize features ▪ Coordinate delivery ▪ Gather user feedback ▪ Measure product performance ▪ Work with Data Owners for data in the product to ensure governance	▪ Approve data access ▪ Define data standards ▪ Ensure data quality and resolve data-related issues ▪ Manage regulatory compliance ▪ Manage business metadata ▪ Coordinate data stewards

innovate achieve lead

BITS Pilani

Pilani|Dubai|Goa|Hyderabad

Data Governance Framework

The Data Governance Framework

- A data governance framework serves as a blueprint and details an organization's structures and processes for managing critical data assets, ensuring that data is used consistently and effectively throughout the organization.
- It defines data ownership and responsibilities and specifies how data should be handled at all stages of the data pipeline to maintain data quality, security and compliance.
- Framework scope and structure depends on an Organization's unique data systems, data sources, industry protocols and government regulations which may be specific to an industry / domain.

The Data Governance framework

The Governance Framework address items such as

- Program goals, roles and duties
- Data standards, policies and processes
- Auditing procedures
- Data governance tools

Pillars of Data Governance Framework

Data Policies and Standards: It defines the policies, procedures, and standards that govern data management within the organization, ensuring consistency and compliance.

Data Roles and Responsibilities: Clearly defined roles and responsibilities are essential for effective data governance, ensuring that everyone understands their role in managing data assets.

Data Quality Management: This focuses on ensuring that data is accurate, complete, and consistent, with processes in place for data validation, cleansing, and enrichment.

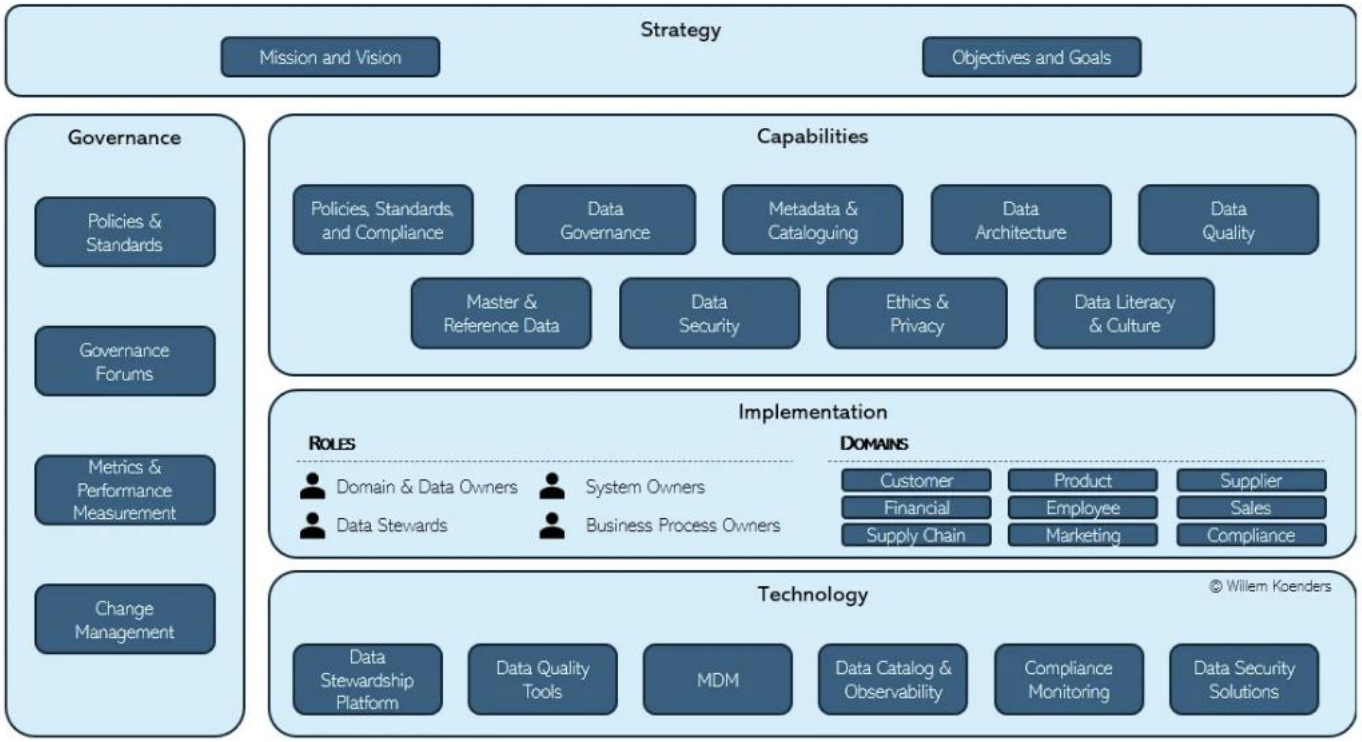
Data Security and Privacy: Data security and privacy are critical components of a data governance framework, with policies and controls in place to protect sensitive data and ensure compliance with relevant regulations.

Data Lifecycle Management: It addresses the management of data throughout its lifecycle, from creation to disposal, ensuring that data is retained and disposed of in accordance with organizational policies and legal requirements.

Data Stewardship: Data stewardship involves the active management and oversight of data assets, ensuring that data is used effectively and efficiently in support of organizational goals.

A Generalized Framework

5 Components:
1. Strategy
2. Governance
3. Capabilities
4. Implementation
5. Technology



Credits: Willem Koenders

innovate achieve lead

BITS Pilani

Pilani|Dubai|Goa|Hyderabad

Topic 2: Regulatory Examples: GDPR, DPDPA, HIPPA etc

Linking Ethics & Governance in the AI era

Why Integration is Critical?

- Ethical intent without governance = No enforcement
- Governance without ethics = Technically compliant but socially harmful

Regulatory Landscape Examples

- General Data Protection Regulation (GDPR)
- Digital Personal Data Protection (DPDP) Act 2023
- HIPPA

innovate achieve lead

BITS Pilani

Pilani|Dubai|Goa|Hyderabad

General Data Protection Regulation GDPR

GDPR

- EU law governing how organizations collect, use, store, and protect personal data.
- Applies to any company handling data of EU residents—regardless of where the company is located.
- Core purpose: give individuals more control over their personal data and ensure transparency in data processing.
- Harmonize data protection laws across EU
- Non-compliance can lead to heavy penalties (up to 20M euros or 4% of global annual turnover).

7 Key Principles

- Lawfulness, fairness, transparency
- Purpose limitation (use data only for stated reasons)
- Data minimization (collect strictly only what's necessary)
- Accuracy
- Storage limitation
- Integrity & confidentiality (security-based access with responsibility)
- Accountability & Explainability

Individual Rights

- Right to access
- Right to rectification
- Right to erasure ("right to be forgotten")
- Right to data portability
- Right to restrict or object to processing
- Rights related to automated decision - making & profiling

Example
A customer can request:
A copy of their stored personal data
Deletion of their account information
Organizations must typically respond within **one month**.

Compliance Obligations

- Obtain valid consent
- Maintain processing records
- Conduct Data Protection Impact Assessments (DPIA)
- Appoint a Data Protection Officer (DPO) where required
- Report data breaches within 72 hours

Data Protection Impact Assessment (DPIA)

- **DPIA** is a structured process used to identify, assess, and minimize privacy risks when processing personal data — especially in high-risk situations.
- Under the General Data Protection Regulation (GDPR), a DPIA is mandatory when data processing is likely to result in **high risk to individuals' rights and freedom.**

When is DPIA Required?

- A DPIA is typically required when:
  - Using **new technologies** (e.g., AI-based profiling)
  - Large-scale processing of sensitive data
  - Systematic monitoring (e.g., CCTV in public spaces)
  - Automated decision-making with legal or significant effects
  - Large-scale tracking of user behavior

If a bank plans to introduce an AI-based loan approval system, it must conduct a DPIA to assess:
Risk of algorithmic bias
Data security vulnerabilities
Impact of automated decisions on customers

innovate achieve lead

BITS Pilani

Pilani|Dubai|Goa|Hyderabad

Digital Personal Data Protection (DPDP) Act

The DPDP Act

- Introduced in 2023
- Governs processing of digital personal data in India
- Applies to:
  - Processing within India
  - Processing outside India if offering goods/services to individuals in India
- Monetary penalties up to ₹250 crore per instance (depending on violation)

Objective

- Protect individuals' digital personal data
- Enable lawful processing
- Balance privacy with innovation and governance
- Scope of Data:
  - Digital personal Data
  - Includes data collected offline but digitized
  - Does *not* cover personal data made publicly available by the individual
- DPDP is not just a compliance law — it:
  - Builds consumer trust
  - Encourages responsible data practices
  - Aligns India with global privacy standards

Terms

- **Data Principal** → Individual whose data is being processed
- **Data Fiduciary** → Entity determining purpose & means of processing
- **Data Processor** → One who Processes data on behalf of Data Fiduciary
- **Consent** → Permission to use / handle data. Must be free, specific, informed, unconditional & unambiguous

Rights and Obligations

- Rights of Data Principals
  - Right to access information
  - Right to correction & erasure
  - Right to grievance redressal
  - Right to nominate another person

- Obligations of Data Fiduciaries
  - Obtain valid consent
  - Implement necessary and reasonable security safeguards
  - Notify breaches
  - Delete data when purpose is completed

Citizen's Rights

Right to information

Individuals will have the right to seek more information on how their data is processed, and the data fiduciary will make this information available in a clear and understandable way.

Right to correction and erasure

Individuals shall have the right to correct inaccurate/incomplete data and erase data that is no longer required for processing.

Right to grievance redressal

Individuals shall have the right to use readily available means of registering a grievance with a data fiduciary.

Right to nominate

Individuals can nominate any other individual to exercise these rights in the event of death or incapacity.

How the Act empowers individuals (charter of rights)

Right to Give or Refuse Consent

Every person has the choice to allow or deny the use of their personal data. Consent must be clear, informed and easy to understand. Individuals may withdraw their consent at any time.

Right to Know How Data is Used

Citizens can seek information on what personal data has been collected, why it has been collected and how it is being used. Organizations must provide this information in a simple form.

Right to Access Personal Data

Individuals can ask for a copy of their personal data that is held by a Data Fiduciary.

Right to Correct Personal Data

People may request corrections to personal data that is inaccurate or incomplete.

Right to Update Personal Data

Citizens can ask for changes when their details have altered, such as a new address or updated contact number.

Right to Erase Personal Data

Individuals may request the removal of personal data in certain situations. The Data Fiduciary must consider and act on this request within the permitted time.

Right to Nominate Another Person

Every individual can appoint someone to exercise their data rights on their behalf. This is helpful in cases of illness or other limitations.

Mandatory Response within Ninety Days

Data Fiduciaries are required to address all requests related to access, correction, updating or erasure within a maximum of ninety days, ensuring timely action and accountability.

Protection During Personal Data Breaches

If a breach takes place, citizens must be informed at the earliest. The message must explain what happened and what steps they can take. This helps people act quickly to reduce harm.

Clear Contact for Queries and Complaints

Data Fiduciaries must provide a point of contact for questions relating to personal data. This may be a designated officer or a Data Protection Officer.

Special Protection for Children

When a child's personal data is involved, verifiable consent from a parent or guardian is required. This consent is needed unless the processing relates to essential services such as healthcare, education or real-time safety.

Special Protection for Persons with Disabilities

If a person with a disability cannot make legal decisions even with support, their lawful guardian must give consent. This guardian must be verified under the relevant laws.

Strategic Comparison between GDPR and DPDP

GDPR

- Comprehensive and globally influential
- Detailed compliance framework
- Strong emphasis on accountability & documentation

DPDP

- Simplified and business-friendly
- Focused on digital ecosystem
- Designed to balance innovation and privacy

GDPR vs DPDP: Individual Rights

Individual Rights

Feature	DPDP	GDPR
Right to Access	✔	✔
Right to Correction	✔	✔
Right to Erasure	✔	✔
Right to Data Portability	✗	✔
Right to Object to Processing	Limited	✔
Automated Decision Rights	Not detailed	Explicitly covered

GDPR vs DPDP: Individual Rights

Organizational Obligations

Requirement	DPDP	GDPR
Lawful Basis	Primarily Consent	Multiple bases (consent, contract, legal obligation, etc.)
Data Protection Officer	For Significant Data Fiduciaries	For many public/high-risk entities
DPIA	For SDFs	Mandatory for high-risk processing
Record of Processing	Limited	Extensive documentation required

SDF: Significant Data Fiduciaries

innovate achieve lead

BITS Pilani

Pilani|Dubai|Goa|Hyderabad

Health Insurance Portability and Accountability Act

HIPPA

Purpose

- Protect sensitive patient health information
- Improve efficiency and portability of health insurance
- Standardize electronic healthcare transactions

Who Must Comply?

- Covered Entities
  - Healthcare providers
  - Health plans
  - Healthcare clearinghouses
- Business Associates
  - Third parties handling Protected Health Information (PHI)

What is Protected?

- Protected Health Information (PHI)
- Any identifiable health information in electronic, paper, or oral form.

HIPPA Rules

Privacy Rule
Governs use and disclosure of PHI
Grants patients rights:
- Access to medical records
- Request corrections
- Know how their data is used

Security Rule
Protects electronic PHI (ePHI)
Requires:
- Administrative safeguards
- Physical safeguards
- Technical safeguards

Breach Notification Rule
Requires notification to affected individuals
Notification to regulators and sometimes media

Penalties
Civil penalties up to $1.5 million per year (category-based)
Criminal penalties for intentional misuse

innovate achieve lead

BITS Pilani

Pilani|Dubai|Goa|Hyderabad

Topic 3: Data Anonymization

What is Data Anonymization

- **Data anonymization** is the process of transforming personal data so that individuals can no longer be identified — directly or indirectly.
- Once properly anonymized, the data is no longer considered “personal data” under many privacy laws (e.g., General Data Protection Regulation).

Why it matters?

- Enables safe data sharing and analytics
- Reduces privacy risk
- Supports AI/ML model training
- Helps with regulatory compliance

Example:
Before anonymization:
Name: Priya Sharma, Age: 32, ZIP: 560034
After anonymization:
Age Range: 30–35, Region: Bengaluru

Anonymization	Pseudonymization
Irreversible	Reversible with key
Cannot re-identify individual	Can re-identify if key exists
No longer personal data (if done properly)	Still considered personal data

Techniques

- Data Masking (hide specific values)
- Aggregation (group-level reporting)
- Generalization (reduce precision)
- Suppression (remove identifiers)
- Noise Addition (slight random variations)
- K-Anonymity / L-Diversity / T-Closeness (privacy-preserving models)

Demo

```
Original Data:

           Name  Age     PIN Medical_Condition  Annual_Income
0  Priya Sharma   32  560034          Diabetes         850000
1   Rahul Mehta   45  110001      Hypertension        1200000
2     Anita Rao   29  400001            Asthma         650000
3  Vikram Singh   52  600020     Cardiac Issue        1500000
```

Step 1: suppression of identifiable data (Name)
Step 2: generalization – convert age to age range
Step 3: masking - pincode lower digits are masked
Step 4: noise addition – random noise added to income

```
Anonymized Data:

     Age     PIN Medical_Condition  Annual_Income
0  30-40  560***          Diabetes         845795
1  40-50  110***      Hypertension        1180860
2  20-30  400***            Asthma         668158
3  50-60  600***     Cardiac Issue        1491284
```

Risks & Best Practices

Key Risks:

- Re-identification attacks using external datasets
- Linkage with publicly available data
- Over-anonymization reducing data utility

Best Practices:

- Apply privacy-by-design principles
- Conduct re-identification risk testing
- Use differential privacy for advanced analytics
- Document methodology and limitations

innovate achieve lead

BITS Pilani

Pilani|Dubai|Goa|Hyderabad

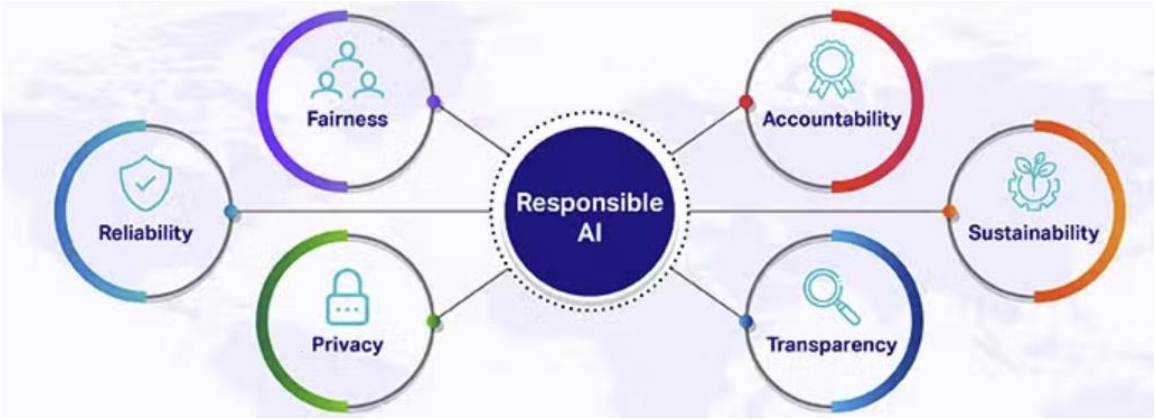
Topic 4: Responsible AI and Sustainability in AI

Responsible AI

- Responsible AI focuses on creating ethical systems and solutions, while ethical AI aims for moral integrity.
- Responsible AI makes it easy for businesses to scale using AI.
- Ethical AI strives for justice but may not always prioritize speed or efficiency.

Responsible AI

- Responsible AI is an approach that focuses on ethical and legal aspects in both development and deployment.
- It aims to create safe, reliable, and morally sound AI. Implementing responsible AI aims to boost openness and minimize problems like AI bias.



Ethical AI

- Ethical AI refers to creating artificial intelligence systems that focus on fairness, transparency, accountability, and respect for human values.
- It makes choices that respect everyone's rights and follow moral guidelines.
- It is about treating all users equally, be open about decisions, and be responsible for any outcomes.
  - An example would be an AI system in hiring that does not favor or disfavor candidates based on gender or ethnicity.

Responsible & Ethical AI

Criteria	Responsible AI	Ethical AI
Goal	Aims to create AI for safe, ethical, and transparent interactions with users.	Aims to create AI that makes morally sound decisions and treats all users fairly.
Scope	Can be applied to various sectors, from healthcare to finance.	Addresses broader societal values like fairness, accountability, and transparency.
Implementation	Involves a multi-disciplinary approach, including legal experts for governance.	Also requires a multi-disciplinary team, but with more focus on ethics and moral awareness
User Experience	Strives for a balanced experience that is both efficient and ethical.	Prioritizes a fair and unbiased experience, potentially at the expense of speed.

Role of Data

Data acts as the backbone for both Responsible and Ethical AI systems.

Data in Responsible AI

- **Safety:** Data collected must be secure and privacy-focused to protect users.
- **Governance:** Detailed data logs are maintained for accountability and traceability.
- **Quality:** High-quality, unbiased data is essential for ethical machine learning models.

Data in Ethical AI

- **Quality:** Needs carefully curated, unbiased data for training.
- **Transparency:** Data sources must be clear to maintain accountability.

Use reliable data collection services to benefit both types of AI

- **Consistency:** Uniform data allows for accurate, reliable results.
- **Comprehensive:** A broad scope of data allows the AI to make well-rounded decisions.

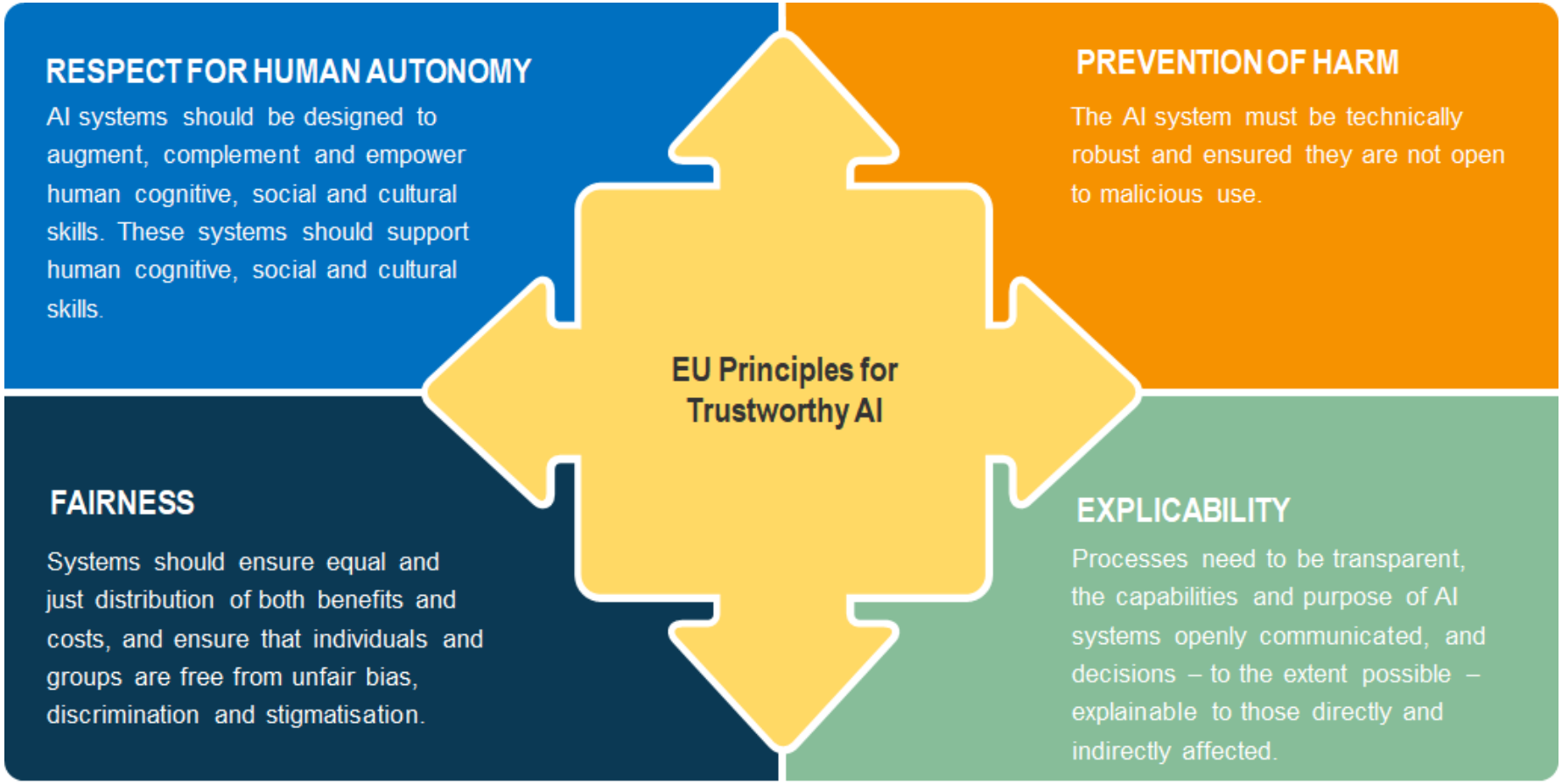
6 Facets of Responsible AI

1. Human Design: Tailoring AI to comprehend, adapt, and cater effectively to diverse needs of humans. Develop human centric AI.
2. Fairness: Guarantee AI as a benign tool, preventing it from perpetuating societal biases or disadvantaging certain demographics inadvertently. Unbiased AI is the essence of fairness.
3. Explainability: AI should be transparent, understandable and rationalize its decisions. Actions should be explainable.

6 Facets of Responsible AI

4. Security: Safeguarding AI from malicious intents or accidental breaches. Important in the current day cybersecurity panorama.
5. Reliability: refers to consistent, accurate functioning under diverse scenarios.
6. Compliance: Regulatory compliance with legal, ethical and social norms ensures legal congruity, ensures righteousness and alignment with social norms.

EU Trustworthy AI



Organization's Best practices

- Establish Data Ethics Committee
- Conduct algorithmic bias audits
- Implement data minimization principles
- Create explainable AI frameworks
- Regular compliance and risk reviews

Summary

- Studied the concept of Metrics and KPIs for defining the performance of a an aspect of the business.
- Identified various KPIs as per the business / functional activity
- Studied the working of a few KPIs
- Understood how the KPIs are represented and displayed in card or gauge vislualizations

Questions?